

Corrigé du TP : Déploiement de BitLocker et Active Directory

Configuration de la Stratégie de Groupe (GPO)

Paramètres activés et justifiés :

- **Stocker les informations de récupération BitLocker dans les services de domaine Active Directory :** Ce paramètre ordonne au système de transmettre la clé de récupération (48 chiffres) au Contrôleur de Domaine plutôt que de laisser l'utilisateur la sauvegarder sur une clé USB non sécurisée.
- **Ne pas autoriser BitLocker à commencer le chiffrement tant que les informations de récupération ne sont pas stockées dans AD DS :** C'est le garde-fou absolu pour un architecte. Il garantit mathématiquement qu'aucun serveur ne sera chiffré si le Contrôleur de Domaine est injoignable ou si la sauvegarde de la clé a échoué. Cela évite le ransomware "auto-infligé" en cas de perte de la clé.
- **Autoriser BitLocker sans un module de plateforme sécurisée (TPM) compatible :** Ce paramètre est une exception nécessaire pour les environnements de laboratoire ou les anciennes machines virtuelles ne disposant pas de vTPM. Il permet d'utiliser un protecteur logiciel (mot de passe).

Application sur la machine cible

Commandes exécutées :

- gpupdate /force
- Get-BitLockerVolume -MountPoint "C:"

Explication : Avant de lancer le chiffrement, il est impératif de forcer l'application de la GPO. Si le chiffrement est lancé avant la réception de la stratégie, la clé de secours ne sera pas envoyée à l'Active Directory, créant une vulnérabilité de type "perte de données".

Activation du Chiffrement

Commandes exécutées :

- \$SecurePassword = ConvertTo-SecureString "Formation2026!" -AsPlainText -Force

- Enable-BitLocker -MountPoint "C:" -PasswordProtector \$SecurePassword
-RecoveryPasswordProtector -EncryptionMethod XtsAes256 -UsedSpaceOnly
-SkipHardwareTest

Explication :

- **PasswordProtector** : On utilise le mot de passe comme clé de déverrouillage au démarrage (Ring 0) en substitution du TPM.
- **RecoveryPasswordProtector** : Ordonne la création de la fameuse clé à 48 chiffres qui sera envoyée à l'AD.
- **XtsAes256** : C'est le standard de chiffrement recommandé par l'ANSSI pour les disques locaux.
- **UsedSpaceOnly** : Permet un chiffrement quasi instantané dans le cadre d'un lab, en ne chiffrant que les secteurs contenant des données (à éviter en production sur un disque ayant déjà contenu des données sensibles non chiffrées).

Validation de la sauvegarde dans Active Directory

Commandes exécutées :

- Get-ADObject -Filter {ObjectClass -eq 'msFVE-RecoveryInformation'} -Properties msFVE-RecoveryPassword

Explication de l'audit : Cette commande, exécutée sur le Contrôleur de Domaine, est la preuve finale de l'architecture. Elle interroge la base de données LDAP à la recherche des objets de type **msFVE-RecoveryInformation**. Le fait de voir la clé en clair remonter dans la console prouve que le mécanisme de séquestre (Key Escrow) de l'Active Directory a fonctionné, validant ainsi l'exigence de résilience.